

Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО

Факультет безопасности информационных технологий

Дисциплина:

«Теория информационной безопасности и методология защиты информации»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №1

«Исследование баз данных угроз и уязвимостей. Калькулятор уязвимостей»

Выполнили:

Пахомов Владимир Юрьевич, студент группы N3250



(подпись)

Проверил:

Есипов Дмитрий Андреевич, ассистент ФБИТ

(отметка о выполнении)

(подпись)

Санкт-Петербург

2025г.

СОДЕРЖАНИЕ

ВЕДЕНИЕ.....	3
1. ОПИСАНИЕ БАЗ ДАННЫХ УГРОЗ И УЯЗВИМОСТЕЙ.....	4
1.1 ФСТЭК.....	4
1.2. Exploit-DB.....	5
1.3. CVE.....	6
1.4. Vulners.....	7
1.5. CERT/CC.....	8
2. КАЛЬКУЛЯТОР CVSS. ОЦЕНКА ОПАСНОСТИ ПО МЕТРИКАМ.....	9
2.1 Базовые метрики. Задача 1.а.....	9
2.2 Временные метрики. Задача 2.б.....	9
2.3 Контекстные метрики. Задача 3.в.....	9
3. СРАВНЕНИЕ CVSSv4 С ПРЕДЫДУЩИМИ ВЕРСИЯМИ.....	11
ЗАКЛЮЧЕНИЕ.....	12
СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ.....	13

ВЕДЕНИЕ

Цель работы — получить знания и навыки работы с различными базами данных угроз и уязвимостей.

Для достижения поставленной цели необходимо решить следующие задачи:

- проанализировать и описать несколько баз данных из открытых источников;
- воспользоваться калькулятором метрик для оценки уязвимости.

1. ОПИСАНИЕ БАЗ ДАННЫХ УГРОЗ И УЯЗВИМОСТЕЙ

1.1 ФСТЭК

Федеральная служба по техническому и экспортному контролю содержит список известных уязвимостей. Каждая уязвимость имеет свой собственный уникальный код, наименование и описание уязвимости, классификация по типу, уровень опасности и список уязвимых устройств.

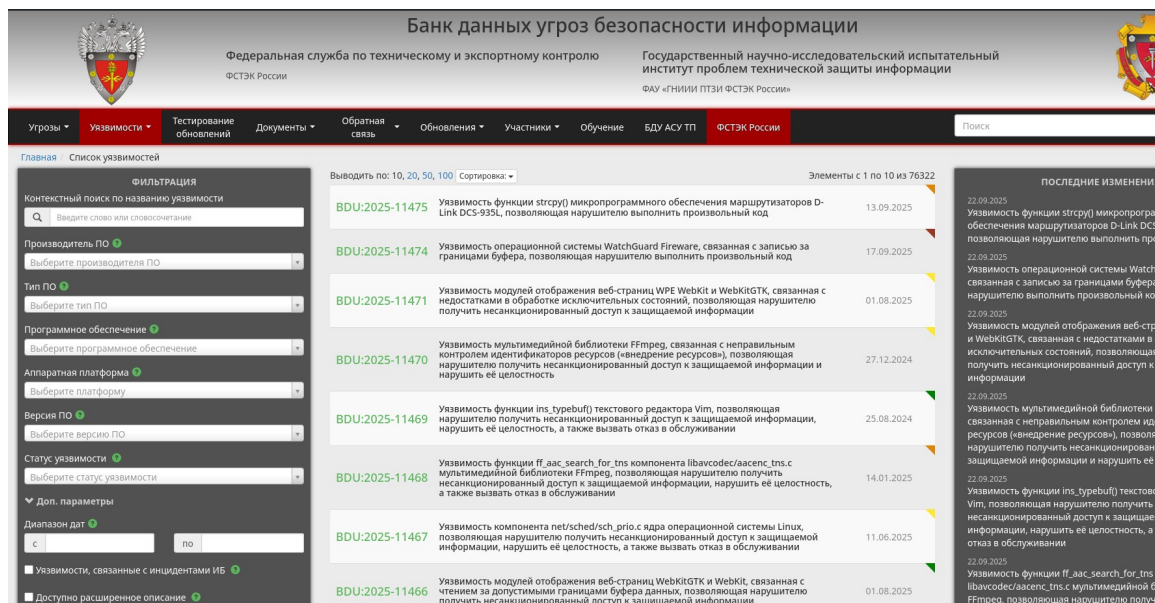
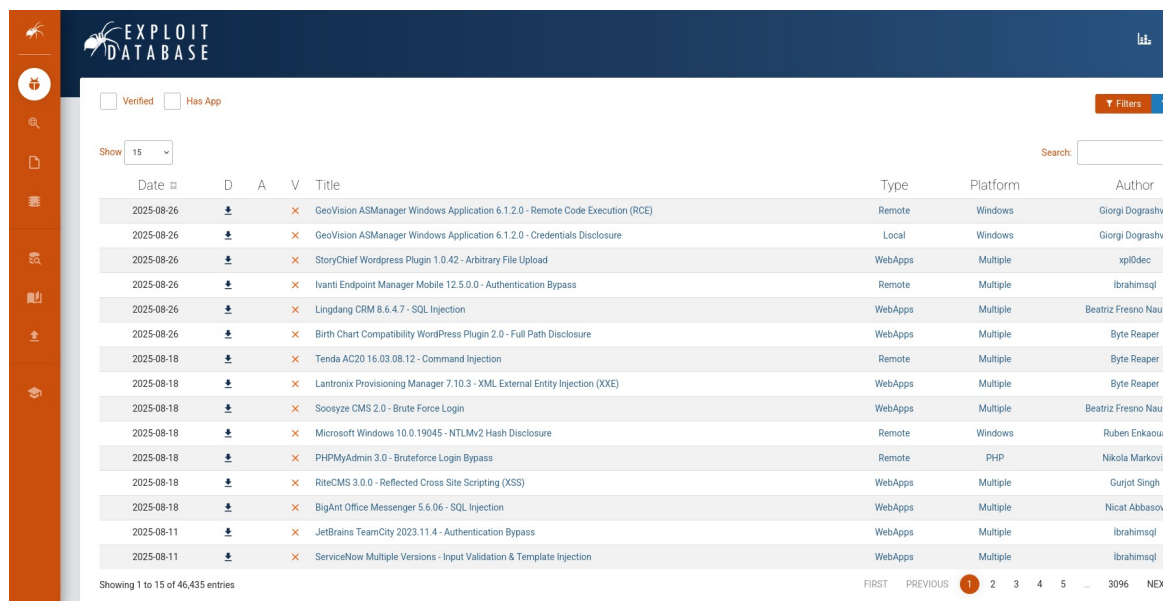


Рисунок 1 — База данных ФСТЭК

1.2. Exploit-DB

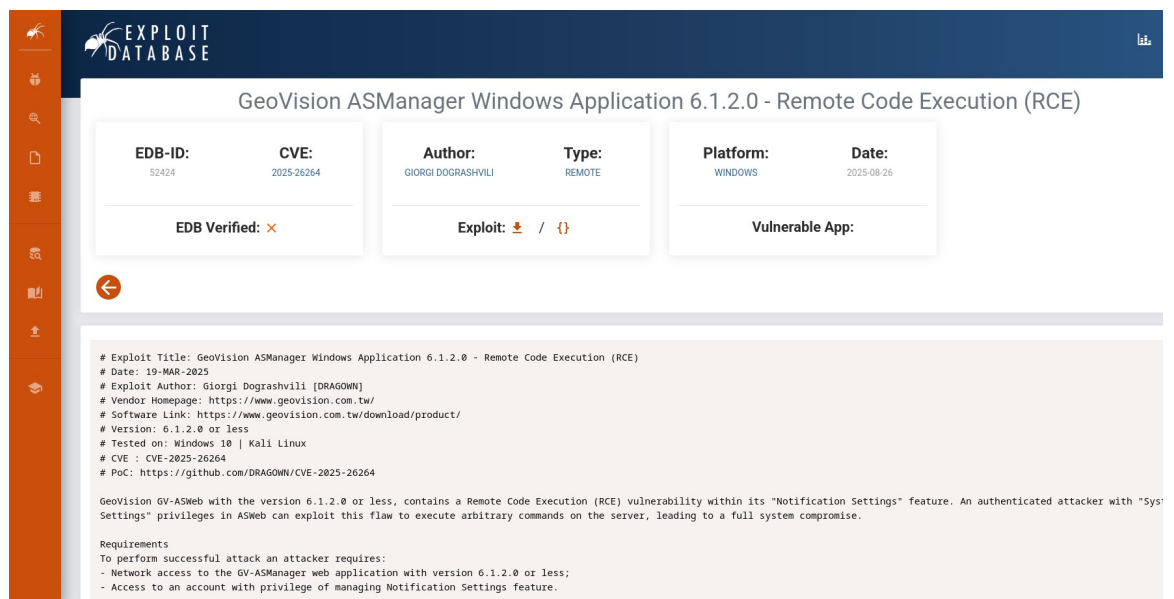
Публичная база данных эксплоитов, шелкодов и PoC кодов. Каждый эксплоит содержит уникальный идентификатор CVE, дату публикации, заголовок, тип, платформу и автора публикации. Также есть возможность скачать эксплоит. Также в дистрибутив Kali Linux есть встроенная CLI утилита searchsploit для поиска уязвимостей из базы данных.



The screenshot shows the Exploit-DB main page. At the top, there's a header with the Exploit-DB logo and a search bar. Below the header, there are filters for 'Verified' and 'Has App'. A table lists various exploits with columns for Date, D (Download), A (Author), V (Verified), Title, Type, Platform, and Author. The table shows 15 entries, with a search bar on the right. At the bottom, there's a pagination bar showing 'Showing 1 to 15 of 46,435 entries' and navigation links like 'FIRST', 'PREVIOUS', '1', '2', '3', '4', '5', '3096', and 'NEXT'.

Date	D	A	V	Title	Type	Platform	Author
2025-08-26	📄	✗		GeoVision ASManager Windows Application 6.1.2.0 - Remote Code Execution (RCE)	Remote	Windows	Giorgi Dograshvili
2025-08-26	📄	✗		GeoVision ASManager Windows Application 6.1.2.0 - Credentials Disclosure	Local	Windows	Giorgi Dograshvili
2025-08-26	📄	✗		StoryChief Wordpress Plugin 1.0.42 - Arbitrary File Upload	WebApps	Multiple	xpl0dec
2025-08-26	📄	✗		Ivanti Endpoint Manager Mobile 12.5.0.0 - Authentication Bypass	Remote	Multiple	Ibrahimsgl
2025-08-26	📄	✗		Lingdang CRM 8.6.4.7 - SQL Injection	WebApps	Multiple	Beatriz Fresno Nau
2025-08-26	📄	✗		Birth Chart Compatibility WordPress Plugin 2.0 - Full Path Disclosure	WebApps	Multiple	Byte Reaper
2025-08-18	📄	✗		Tenda AC20 16.03.08.12 - Command Injection	Remote	Multiple	Byte Reaper
2025-08-18	📄	✗		Lantronix Provisioning Manager 7.10.3 - XML External Entity Injection (XXE)	WebApps	Multiple	Byte Reaper
2025-08-18	📄	✗		Soosyze CMS 2.0 - Brute Force Login	WebApps	Multiple	Beatriz Fresno Nau
2025-08-18	📄	✗		Microsoft Windows 10.0.19045 - NTLMv2 Hash Disclosure	Remote	Windows	Ruben Enkaou
2025-08-18	📄	✗		PHPMyAdmin 3.0 - Brute Force Login Bypass	Remote	PHP	Nikola Markovi
2025-08-18	📄	✗		RiteCMS 3.0.0 - Reflected Cross Site Scripting (XSS)	WebApps	Multiple	Gurjot Singh
2025-08-18	📄	✗		BigAnt Office Messenger 5.6.06 - SQL Injection	WebApps	Multiple	Nicat Abbasov
2025-08-11	📄	✗		JetBrains TeamCity 2023.11.4 - Authentication Bypass	WebApps	Multiple	Ibrahimsgl
2025-08-11	📄	✗		ServiceNow Multiple Versions - Input Validation & Template Injection	WebApps	Multiple	Ibrahimsgl

Рисунок 1 — База данных Exploit-DB. Главная страница



The screenshot shows the Exploit-DB page for a specific exploit. The title is 'GeoVision ASManager Windows Application 6.1.2.0 - Remote Code Execution (RCE)'. Below the title, there are several boxes containing metadata: EDB-ID: 52424, CVE: 2025-26264, Author: GIORGI DOGRASHVILI, Type: REMOTE, Platform: WINDOWS, Date: 2025-08-26. There are also boxes for 'EDB Verified: ✗', 'Exploit: 📄 / {}', and 'Vulnerable App:'. Below these boxes, there's a section for the exploit details, including the exploit title, date, author, vendor homepage, software link, version, tested on, CVE, and PoC. The PoC is a URL to a GitHub repository. The exploit description states that GeoVision GV-ASWeb with the version 6.1.2.0 or less, contains a Remote Code Execution (RCE) vulnerability within its 'Notification Settings' feature. An authenticated attacker with 'Sys Settings' privileges in ASWeb can exploit this flaw to execute arbitrary commands on the server, leading to a full system compromise. The requirements for a successful attack are: Network access to the GV-ASManager web application with version 6.1.2.0 or less, and Access to an account with privilege of managing Notification Settings feature.

GeoVision ASManager Windows Application 6.1.2.0 - Remote Code Execution (RCE)

EDB-ID: 52424 **CVE:** 2025-26264 **Author:** GIORGI DOGRASHVILI **Type:** REMOTE **Platform:** WINDOWS **Date:** 2025-08-26

EDB Verified: ✗ **Exploit:** 📄 / {} **Vulnerable App:**

Exploit Details:

Exploit Title: GeoVision ASManager Windows Application 6.1.2.0 - Remote Code Execution (RCE)
Date: 19-MAR-2025
Exploit Author: Giorgi Dograshvili [DRAGOWN]
Vendor Homepage: https://www.geovision.com.tw/
Software Link: https://www.geovision.com.tw/download/product/
Version: 6.1.2.0 or less
Tested on: Windows 10 | Kali Linux
CVE : CVE-2025-26264
PoC: https://github.com/DRAGOWN/CVE-2025-26264

GeoVision GV-ASWeb with the version 6.1.2.0 or less, contains a Remote Code Execution (RCE) vulnerability within its "Notification Settings" feature. An authenticated attacker with "Sys Settings" privileges in ASWeb can exploit this flaw to execute arbitrary commands on the server, leading to a full system compromise.

Requirements

To perform successful attack an attacker requires:

- Network access to the GV-ASManager web application with version 6.1.2.0 or less;
- Access to an account with privilege of managing Notification Settings feature.

Рисунок 2 — База данных Exploit-DB. Страница с угрозой

1.3. CVE

Международная система стандартизированной идентификации и каталогизации известных уязвимостей в ПО и информационных системах. Каждая уязвимость имеет свой уникальный код CVE-YYYY-NNNN, краткое стандартизированное описание, дату выявления и уровень опасности, определяемый по системе оценивания CVSS.

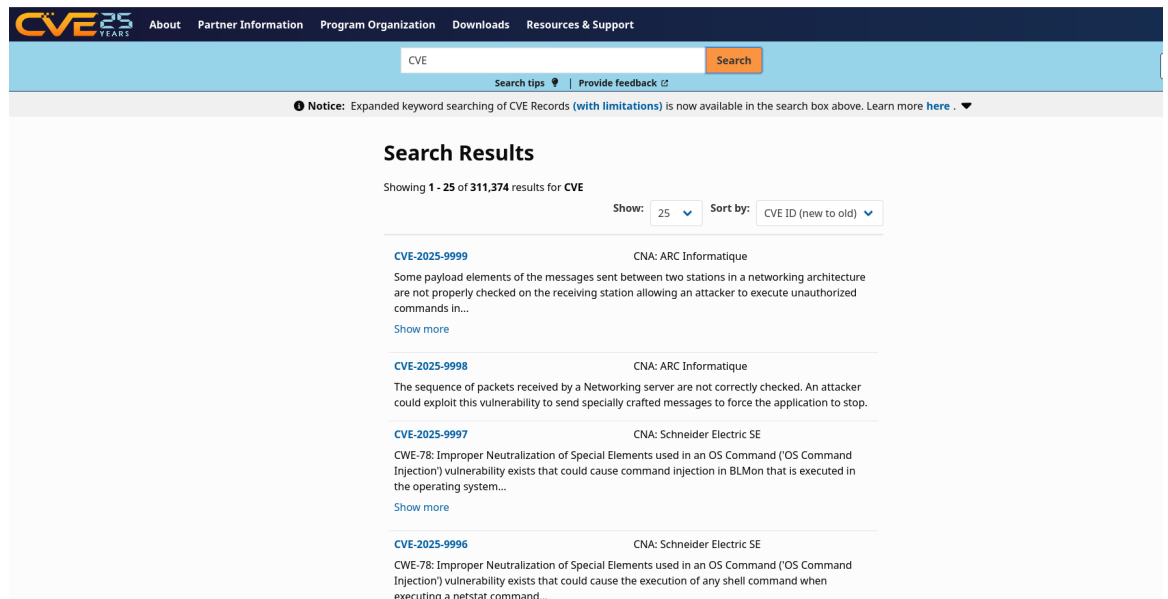


Рисунок 3 — База данных CVE. Главная страница

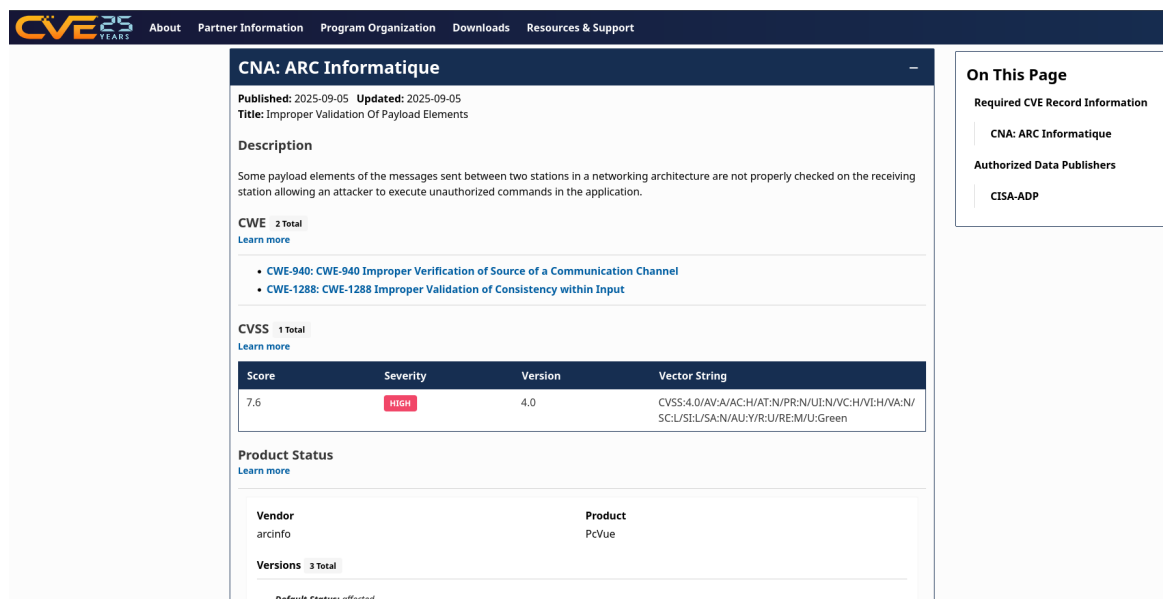


Рисунок 4 — База данных CVE. Страница с угрозой

1.4. Vulners

Содержит сведения о CVE, эксплойтах, патчах безопасности и обновлениях ПО из различных источников: ExploitDB, Metasploit, Github. RedhatCVE и др. Vulners API позволяет интегрировать базу данных в автоматизированные системы управления безопасностью и системы сканирования.

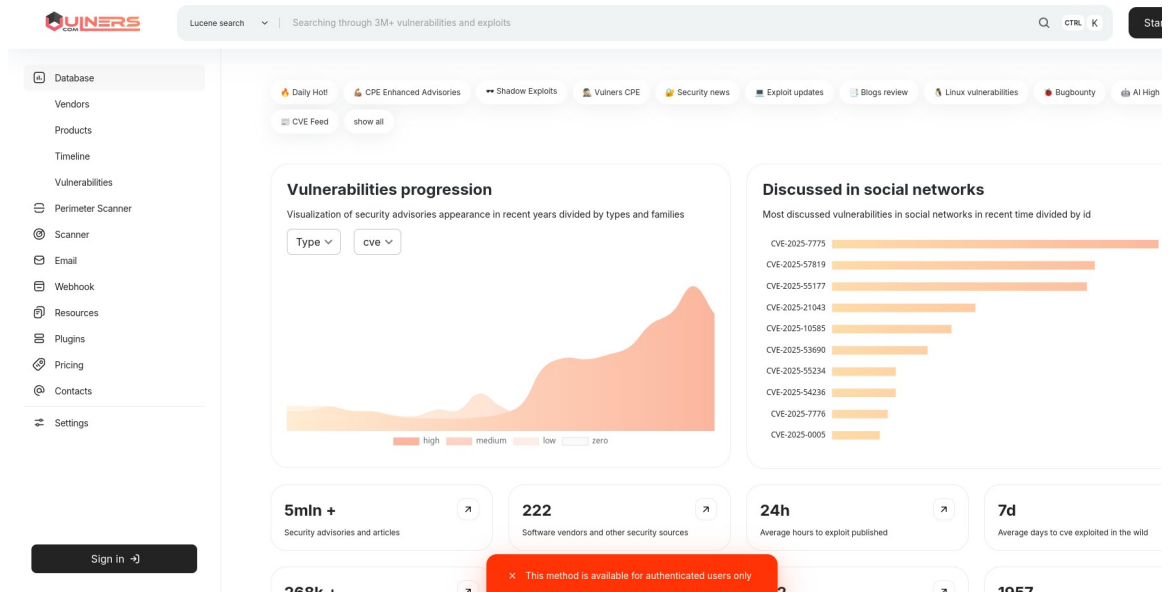


Рисунок 5 — База данных Vulners. Главная страница

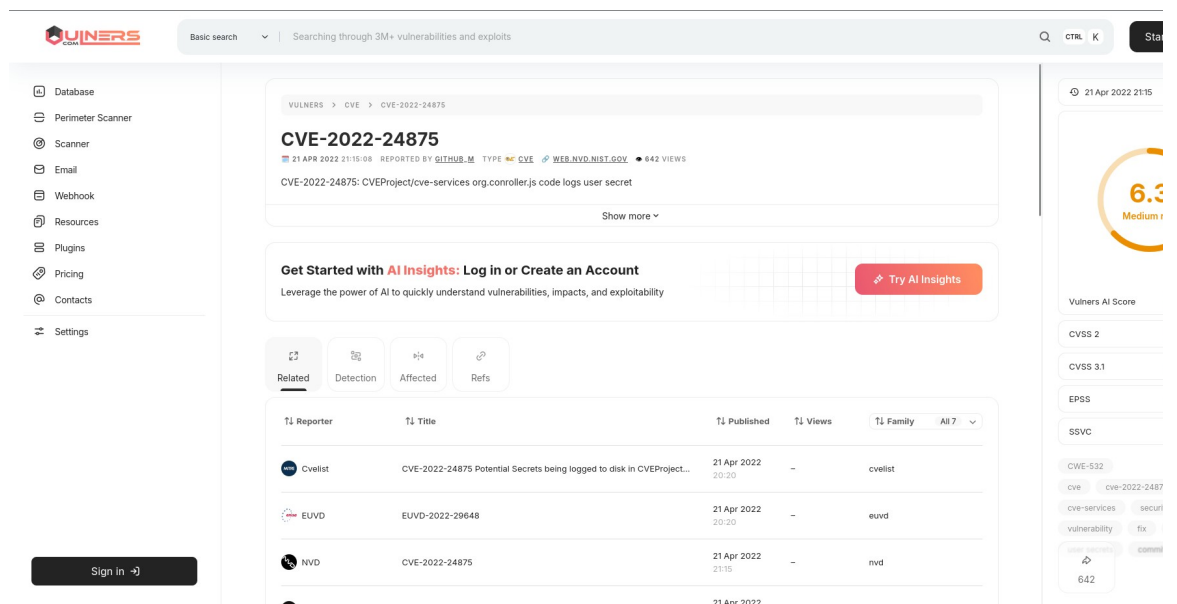


Рисунок 6 — База данных Vulners. Страница с уязвимостью

1.5. CERT/CC

Computer Emergency Response Team Coordination Center ведет собственную базу данных Vulnerability Notes Database (VND). Каждая запись содержит уникальный CVE идентификатор уязвимости, описание, рекомендации по исправлению и ссылки на патчи и эксплойты. CERT/CC считается один из мировых стандартов в области реагирования на инциденты.

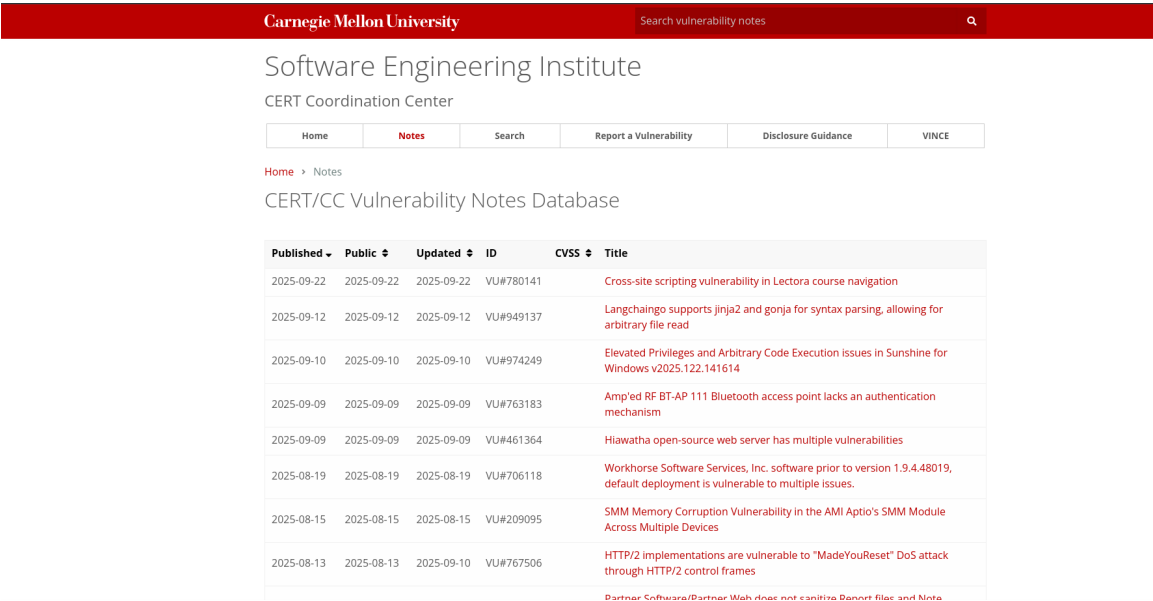


Рисунок 7 — База данных CERT/CC. Главная страница

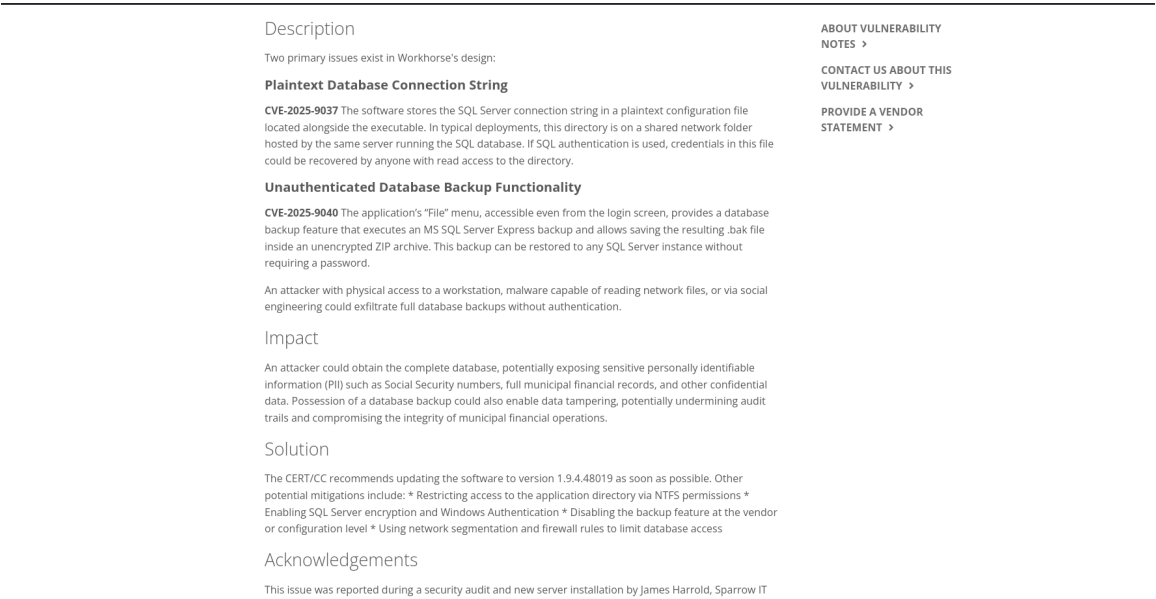


Рисунок 8 — База данных CERT/CC. Страница с уязвимостью

2. КАЛЬКУЛЯТОР CVSS. ОЦЕНКА ОПАСНОСТИ ПО МЕТРИКАМ

2.1 Базовые метрики. Задача 1.а

Атака высокой сложности будет проводится на физический уровень системы, при этом оказывается влияние на другие компоненты системы. Однако атака приводит только к нарушению целостности высокого уровня. Взаимодействие с пользователем не требуется, а уровень привилегий — низкий.

Базовые метрики 4.8

Базовая оценка (BS): 4.8

Вектор атаки (AV): Сетевой (N) | Смежная сеть (A) | Локальный (L) | **Физический (P)**

Сложность атаки (AC): **Высокая (H)** | Низкая (L)

Уровень привилегий (PR): Высокий (H) | **Низкий (L)** | Не требуется (N)

Взаимодействие с пользователем (UI): Требуется (R) | **Не требуется (N)**

Влияние на другие компоненты системы (S): Не оказывает (U) | **Оказывает (C)**

Влияние на конфиденциальность (C): Не оказывает (N) | Низкое (L) | Высокое (H)

Влияние на целостность (I): Не оказывает (N) | Низкое (L) | **Высокое (H)**

Влияние на доступность (A): Не оказывает (N) | Низкое (L) | Высокое (H)

Рисунок 9 — Калькулятор базовых метрик

2.2 Временные метрики. Задача 2.б

Предполагается, что есть сценарий для средств эксплуатации, не определена доступность средств устранения и подтверждена степень доверия к источнику информации об уязвимости.

Временные метрики 4.7

Временная оценка (TS): 4.7

Доступность средств эксплуатации (E): Не определено (X) | Высокая (H) | **Есть сценарий (F)** | Есть PoC-код (P) | Теоретическая (U)

Доступность средств устранения (RL): **Не определено (X)** | Недоступно (U) | Рекомендация (W) | Временное (T) | Официальное (O)

Степень доверия к информации об уязвимости (RC): Не определено (X) | **Подтверждена (C)** | Достоверные отчеты (R) | Отчеты (U)

Рисунок 10 — Калькулятор Временных метрик

2.3 Контекстные метрики. Задача 3.в

К уровню обеспечения КЦД заданы высокие требования, влияние на них также оказывается высоким. При этом проводится атака низкой сложности на локальный уровень системы. Уровень привилегий в данном

случае - высокий, взаимодействия с пользователем не происходит.
Оказывается ли влияние на другие компоненты системы - неизвестно.

Контекстные метрики 7.2 CR/H/IR/H/AR/H/MAV/L/MACL/MPR/H/M

Контекстная оценка (ES): 7.2

Требования к конфиденциальности (CR):

Не определено (X)	Низкие (L)	Средние (M)	Высокие (H)
-------------------	------------	-------------	-------------

Требования к целостности (IR):

Не определено (X)	Низкие (L)	Средние (M)	Высокие (H)
-------------------	------------	-------------	-------------

Требования к доступности (AR):

Не определено (X)	Низкие (L)	Средние (M)	Высокие (H)
-------------------	------------	-------------	-------------

Вектор атаки (корр.) (MAV):

Не определено (X)	Сетевой (N)	Смежная сеть (A)	Локальный (L)	Физиче (P)
-------------------	-------------	------------------	---------------	------------

Сложность атаки (корр.) (MAC):

Не определено (X)	Высокая (H)	Низкая (L)
-------------------	-------------	------------

Уровень привилегий (корр.) (MPR):

Не определено (X)	Высокий (H)	Низкий (L)	Не требуется (N)
-------------------	-------------	------------	------------------

Взаимодействие с пользователем (корр.) (MUI):

Не определено (X)	Требуется (R)	Не требуется (N)
-------------------	---------------	------------------

Влияние на другие компоненты системы (корр.) (MS):

Не определено (X)	Не оказывает (U)	Оказывает (C)
-------------------	------------------	---------------

Влияние на конфиденциальность (корр.) (MC):

Не определено (X)	Не оказывает (N)	Низкое (L)	Высокое (H)
-------------------	------------------	------------	-------------

Влияние на целостность (корр.) (MI):

Не определено (X)	Не оказывает (N)	Низкое (L)	Высокое (H)
-------------------	------------------	------------	-------------

Влияние на доступность (корр.) (MA):

Не определено (X)	Не оказывает (N)	Низкое (L)	Высокое (H)
-------------------	------------------	------------	-------------

Рисунок 11 — Калькулятор контекстных метрик

3. СРАВНЕНИЕ CVSSv4 С ПРЕДЫДУЩИМИ ВЕРСИЯМИ

Номенклатура оценок:

Появились новые обозначения CVSS-B, CVSS-BT, CVSS-BE, CVSS-BTE, где В — базовые метрики, Т — метрики угроз и Е — контекстные метрики. Это позволяет более гибко выбирать грубину оценки.

Базовые метрики:

Attack Complexity разделен на сложность атаки (AC) и дополнительные условия эксплуатации (AT).

«Взаимодействие с пользователем (UI)» теперь с тремя уровнями: None (N), Passive (P) и Active (A).

Убрана метрика «Область применения (S)» и вместо неё введены 2 уровня воздействия: VC/VI/VA — влияние на уязвимую систему и SC/SI/SA — влияние на связанные системы.

Метрики угроз:

Переименовали «Временные метрики» в «Метрики угроз», удалены «Уровень исправления (RL)» и «Достоверность отчета (RC)», значения «High (H)» и «Functional (F)» для метрики «Доступность средств эксплуатации (E)» объединены в одно значение «Attacked (A)».

Дополнительные метрики:

- безопасность (S);
- возможность автоматизации (AU);
- восстановление (R);
- контроль над ресурсами (V);
- усилия по реагированию (RE);
- срочность устранения уязвимости (U).

ЗАКЛЮЧЕНИЕ

В наше время есть достаточно большое количество открытых источников с структурированной информацией об известных уязвимостях, способах их устранения и рекомендациях. Сравнение версий оценки уязвимостей CVSS показало, что CVSSv4 требует больше усилий для внедрения, но при этом она более гибкая и лучше отражает реальные риски и приоритеты, чем ее предыдущая версия 3.1.